釣魚信件
自動化寄送系統

釣魚郵件自動化系統 N8N

專案背景
在現今企業的環境當中，資安意識已成為防禦社交工程攻擊的關鍵。然而，傳統的演練往往需要人工設計郵件、分配場景、寄送與追蹤等步驟，不僅耗時，還容易產生重複模板，降低演練效果。 • **資安威脅現況**：釣魚郵件仍是企業最常見的攻擊手法之一。 • **演練目的**：透過模擬真實釣魚郵件，提高員工資安意識，避免落入詐騙陷阱。 • **目標**：建立一套可自動生成、多樣化且合規的演練郵件系統。

1.自動化：將演練郵件的產生、驗證與寄送全程自動化。

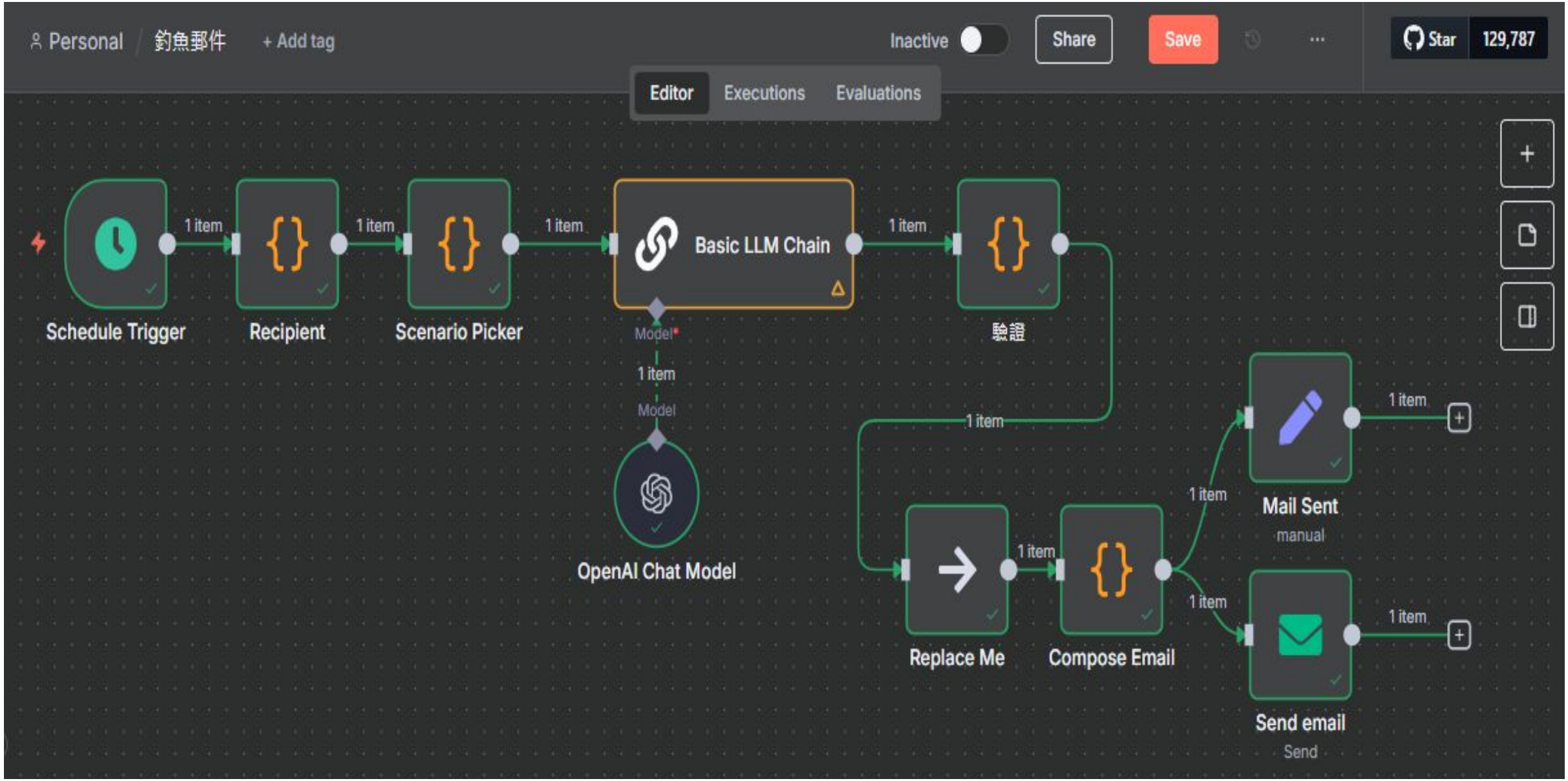
2. 多樣性：結合LLM生成技術，確保不同收件人、不同場景的郵件內容具有差異性。

3.合規與安全：內建驗證機制，避免郵件誤導收件者提供敏感資訊。

4.可追蹤性：建立完整演練紀錄，方便後續分析。

最終目標：在不增加管理成本的情況下，提升員工資安意識並強化企業整體防護力

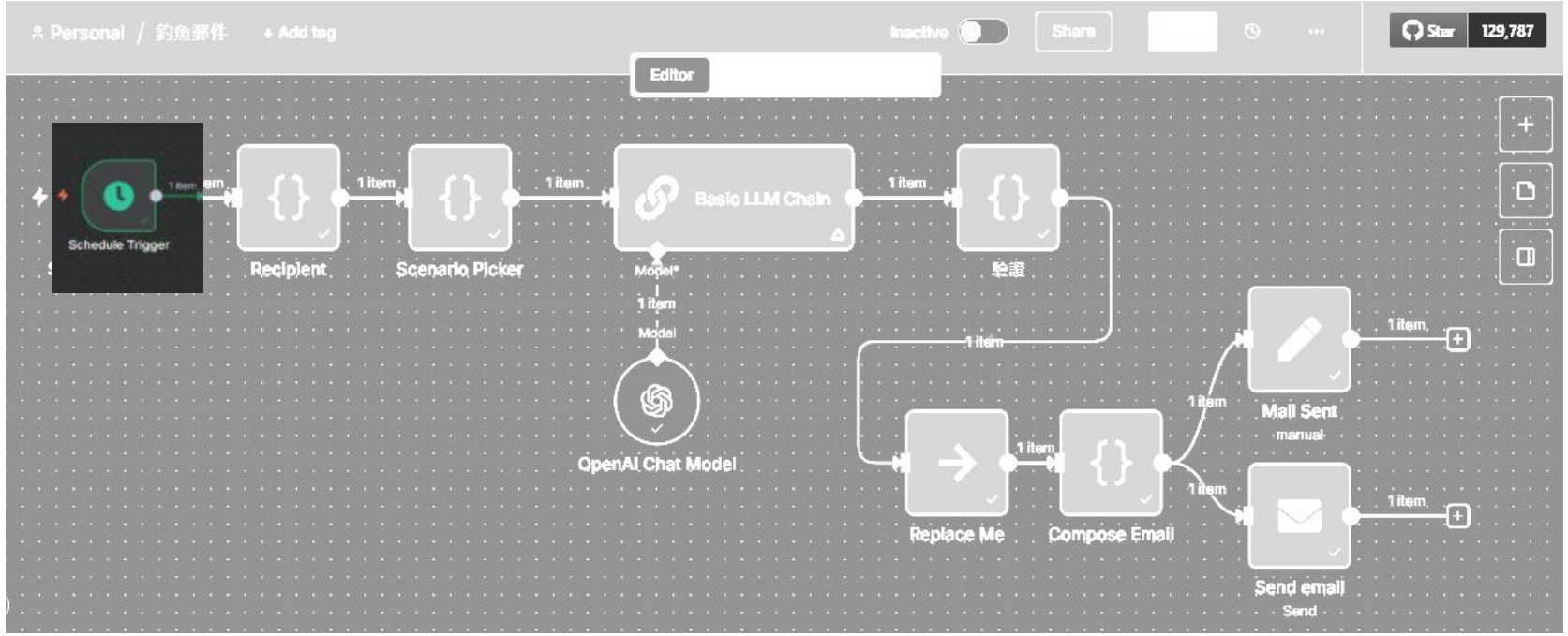
釣魚郵件自動化系統 N8N



釣魚郵件自動化系統 - Node 說明

Schedule Trigger

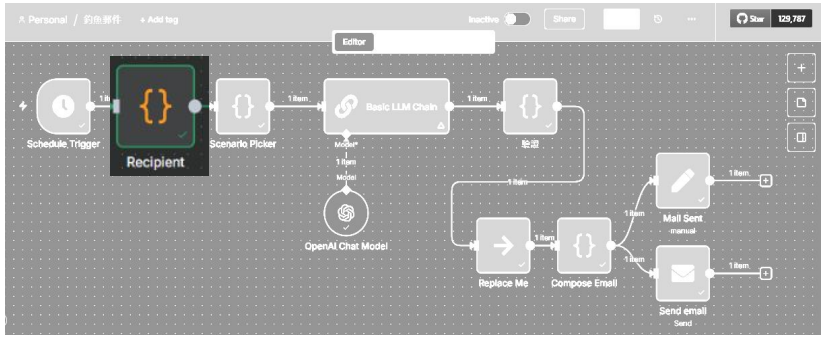
- 負責在預定時間整個釣魚郵件寄信流程
- 可以設定固定的時間區間(例如:每週一次、每月一次、隨機某一天),
  讓演練活動具備**週期性與隨機性**，避免同仁過度依賴經驗判斷而降低演練效果。
- 整個流程的起點，相當於自動排程器，確保系統能持續、穩定運作，而不需要人工手動發送。這樣不僅提升效率，也模擬出真實駭客攻擊常見的「不預期」特性。



釣魚郵件自動化系統 - Node 說明

Recipient

- 負責處理「誰要收到演練郵件」與「演練的識別資訊」，輸出成下游節點可直接消化的結構
- 收件者決定
  - 匯入或隨機抽樣員工名單（包含姓名、部門、Email、userId）。
  - 可依公司需求設計不同的受測群組，例如特定部門或隨機 10% 員工。
- 識別資訊生成
  - 自動產生活動識別碼 (campaignId) 與執行序號 (runId)，方便追蹤每次寄送結果。
  - 保證每位受測者的演練紀錄可完整回溯，利於後續成效分析。
- 內容多樣化
  - 透過 (variantSeed)，使相同主題的釣魚郵件能針對不同員工、部門 產生不同版本，避免被一眼識破。
  - 標題文字、語氣、段落結構、內容、語言都會依照變數改變。

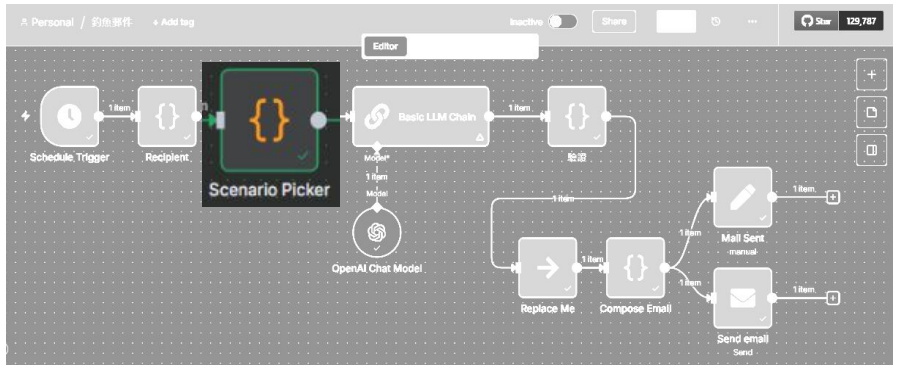



```
const roster = Array.isArray($vars.recipients) &&
$vars.recipients.length
  ? $vars.recipients
  : [
      { email: "alice@example.com", name: "Alice",
department: "Finance", userId: "E0001" },
    ];

const active = roster.filter(r => r.active !== false);

const now = new Date();
const yyyy = now.getFullYear();
const mm   = String(now.getMonth() + 1).padStart(2, '0');
const campaignId = `${yyyy}-${mm}`;
const runId = `${campaignId}-${Date.now()}`;

function makeSeed(r, idx) {
  return `${r.userId || r.email}-${campaignId}-${idx}`;
}

function jitterISO(idx, baseMin = 0, spreadMin = 45) {
  const t = new Date(now.getTime() + (baseMin + (idx %
spreadMin)) * 60 * 1000);
  return t.toISOString();
}

return active.map((r, idx) => ({
  json: {
    ...r,
    campaignId,
    runId,
    variantSeed: makeSeed(r, idx),
    companyName: $vars.companyName || '本公司',
    locale: 'zh-TW',

    sendAt: jitterISO(idx)
```

釣魚郵件自動化系統 - Node 說明

Scenario Picker

- 釣魚郵件自動化系統中的「情境分配核心模組」
- 在收件人確定之後，系統會為每位收件人指派一個特定的情境，決定郵件的語氣、 內容方向、結構呈現方式，最後輸出唯一的 AI 訓練。
- 情境隨機分派
  - 預先定義多種主題，例如信用卡資訊更新、密碼重設通知、帳務異動提醒、權限續期申請、差旅系統異動等。
  - 每一大類情境再細分多個子情境，例如「卡片資訊更新」底下可能包含 *卡片額度異常*、*近期可疑交易提醒* 等。
  - 根據隨機化演算法，確保收件人每次都能收到不同 內容，避免因重複而降低釣魚效果。
- 語氣與風格調整，讓相同情境在不同收件人身上展現出截然不同的樣貌
- 變數種子會用來驅動 LLM（大型語言模型）的輸出，避免 產生過度重複的句子



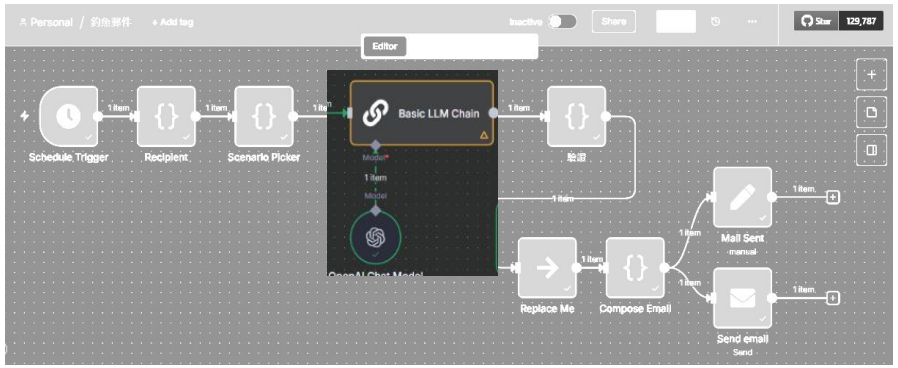

```
const scenarios = [
  { id: 'hr_notice', label: '人資行政通知情境', weight: 1, subs: [
  '年度績效評核結果查詢','年假餘額到期提醒','薪資單下載通知',
  '福利方案異動申請','員工健康檢查報名'
]},
  { id: 'card_update',  label: '卡片資訊更新情境', weight: 1, subs: [
    '卡片額度異常待確認','卡片資料需更新','近期可疑交易提醒','卡片即將到期換卡說明','公司卡籍資料複核'
  ]},
  { id: 'pwd_reset',    label: '密碼重設情境',     weight: 1, subs: [
    '密碼即將到期提醒','偵測到異地登入','新裝置登入驗證','密碼規範更新需重設','近期嘗試登入次數異常'
  ]},
  { id: 'acct_notice',  label: '帳務異動通知情境', weight: 1, subs: [
    '異常費用待釐清','發票資訊補件','退款處理異動','費用分攤調整','月結對帳差異通知'
  ]},
```

```
const tones = ['neutral','formal','urgent_mild','friendly'];
const styles = ['concise','bullet','step_by_step','paragraph'];

const base = 'https://www.google.com';

const weighted = [];
for (const s of scenarios) for (let i=0;i<s.weight;i++) weighted.push(s);

function hash(str){ let h=0; for(let i=0;i<str.length;i++) h=(h*31 + str.charCodeAt(i))>>>0; return h; }
```

釣魚郵件自動化系統 - Node 說明

OpenAI Chat Model

- 接收來自 **Scenario Picker** 的情境設定(包含:情境主題、子情境、tone、style、訓練連結等),並透過 **LLM(大型語言模型)** 自動生成模擬郵件內容。
- 生成規則:
  - **情境驅動**:以 scenarioId + subScenario 作為生成依據,不同收件人雖處於同一個情境,也能因為 tone/style 差異產生不同版本的郵件,提升真實感。
  - **避免敏感資訊**:強制避免出現 **OTP、信用卡號、身分證字號** 等敏感資料,並透過正則檢查與替換機制,確保郵件只會導向**內部訓練網站**。
  - **多樣化風格**:根據 style 屬性生成,例如 concise、bullet、step_by_step、paragraph
  - **長度與可讀性控制**:控制在 **80–200 字**,避免過長或過短,維持像真實公司通知的感覺
  - **系統標籤**:郵件最後都會加上**「此為公司資安演練郵件」**



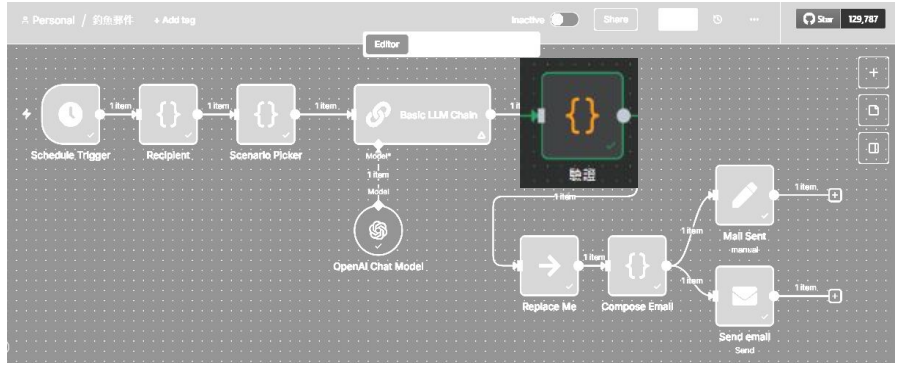
角色:你是台灣中鼎工程顧問公司 Ctci 員工資訊安全意識「釣魚演練郵件」的撰寫助手。你的任務是依指定「演練情境」與「員工屬性」產出內部演練郵件。
硬性規範:

1.僅能使用我提供的 trainingLink 作為唯一連結,要有網址,不可以只有超連結;禁止新增或改寫任何其他網址(含縮網址)。
2.不得要求或引導收件者提供:密碼、OTP、支付資料、個資、住址、身分證/護照、員工編號、生日等。
3.不得冒用真實對外品牌與實體,可用泛稱或虛構名稱(如「公司內部帳務系統」「企業差旅系統」「中鼎大學系統」「中鼎EIP系統」)。
4.內文尾段必須標註:「此為公司資安演練郵件,點擊後將前往訓練頁面」。
5.文字長度 80–200 字,自然專業,不恐嚇、不卡詐。
6.允許根據部門/情境調整措辭與迷惑點(如「卡片額度異常」「密碼到期」「差旅申請待補件」)。
7.只輸出單一 JSON,結構固定:
{ "subject": "...", "bodyText": "...", "bodyHtml": "..." }
8.bodyHtml 與 bodyText 內容一致(HTML 版允許 …
),且所有連結只使用 trainingLink。
9.內容要多樣化:可調整語氣、切入點、主旨模板與措辭;同一情境不同收件人仍應顯著不同。
10.若情境或輸入資訊不完整,自行合理補足內部系統泛稱,但仍不可增加外部品牌或任何新連結。
11.您可以自由選擇要撰寫中文或英文韓文郵件。

釣魚郵件自動化系統 - Node 說明

驗證

- 驗證節點的角色，是在 **LLM 自動產生郵件內容後的「防線」**。它負責解析輸入，檢查內容是否合規，並執行必要的修正與補強，確保寄出的釣魚演練郵件 **不會帶來真實風險**，同時維持訓練效果。
- 解析與檢查必要欄位
  - 驗證 LLM 輸出的 JSON 結構是否完整（必須包含 subject、bodyText、bodyHtml）。
  - 若缺少欄位或格式異常，會直接擋下，避免寄出不完整郵件。
- 敏感資訊過濾
  - 使用正則表達式綁定規則：若 **動詞 (提供/回覆/填寫...) 與敏感詞 (密碼/OTP/信用卡號/身分證...) 的距離小於 12 字**，就會觸發警示並自動替換為安全提示。
- 尾註補強：自動檢查郵件結尾是否包含固定文字**「此為公司資安演練郵件，點擊後將前往訓練頁面。」**
- 與上下游的整合：將結果（安全文本 + 收件者資訊 + 情境資訊）一併輸出，交給 **Compose Email Node** 進行最終的排版與寄送

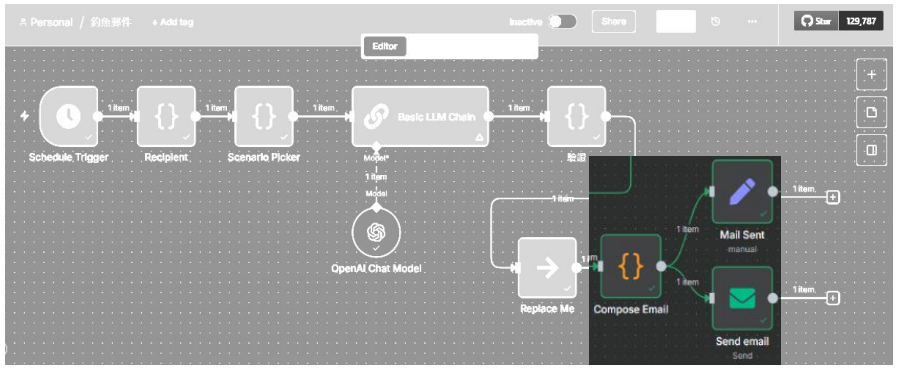



```
10  function scrubSensitive(s) {
11    if (!s) return s;
12    s = s.replace(
13      /(請|敬請|須請|需要).{0,12}(提供|回覆|填寫|上傳|提交|告知|回傳|傳送|寄送|附上).{0,12}(密碼|一次性驗證碼|OTP|信用卡(?:號)?|卡號|CVV|身分證|護照|銀行帳(?:號)?|匯款|支付(?:資訊|資料)?|住址|地址|電話|手機|出生日期)[^。]*。?/gi,
14      '請勿在郵件中提供任何敏感資訊；如需後續操作，請依內部訓練頁面說明進行。'
15    );
16    s = s.replace(/\b(OTP|一次性驗證碼|密碼|信用卡(?:號)?|卡號|CVV|銀行帳(?:號)?|身分證|護照)\b/gi, '敏感資訊');
17    return s;
18  }
19
20  return items.map((it, idx) => {
21    const raw = it.json.text ?? it.json.response ?? it.json.data ?? Object.values(it.json)[0];
22    const ai = parseAi(raw);
23
24    const sp = from(idx, 'Scenario Picker');
25    const rc = from(idx, 'Recipient');
26    const trainingLink = sp.trainingLink || it.json.trainingLink || '';
27
28    if (!ai.subject || !ai.bodyText || !ai.bodyHtml)
29      throw new Error('缺少必要欄 subject/bodyText/bodyHtml');
30
31    const urlRegex = /(https?:\/\/[^\s"'<>()]+)/gi;
32    const allUrls = [...(ai.bodyText.match(urlRegex) || []), ...(ai.bodyHtml.match(urlRegex) || [])];
33    const bad = allUrls.filter(u => !u.startsWith(trainingLink));
34    if (bad.length) throw new Error('偵測到未授權連結：' + bad.join(', '));
35
36    const ACTION = '(提供|回覆|填寫|上傳|提交|告知|回傳|傳送|寄送|附上)';
37    const SECRET = '(密碼|一次性驗證碼|OTP|信用卡(?:號)?|卡號|CVV|身分證|護照|銀行帳(?:號)?|匯款|支付(?:資訊|資料)?|住址|地址|電話|手機|出生日期)';
38    const forbid = new RegExp(`${ACTION}.{0,12}${SECRET}|${SECRET}.{0,12}${ACTION}`, 'i');
39    if (forbid.test((ai.bodyText || '') + '\n' + (ai.bodyHtml || ''))) {
40      ai.bodyText = scrubSensitive(ai.bodyText);
41      ai.bodyHtml = scrubSensitive(ai.bodyHtml);
```

釣魚郵件自動化系統 - Node 說明

Compose Email

- 將先前組合完成的演練郵件正式寄出。它會設定寄件人與收件人，並呼叫郵件伺服器將內容發送。
- Send Email：
  - 負責設定寄件人與收件人
  - 設定好 API Key 即可串接信件發送功能
- Mail Sent：
  - 記錄寄件結果
  - 儲存 郵件標題 subject、情境代號 scenarioId、寄信時間 sentAt 等資訊，方便後續追蹤




```
35  const email = firstNonEmpty(it.json.email, it.json.to, pick(idx,'驗證','email'), pick(idx,'Scenario Picker','email'), pick(idx,'Recipient','email'), fallbackTo);
36  const name        = firstNonEmpty(it.json.name, pick(idx,'驗證','name'), pick(idx,'Scenario Picker','name'), pick(idx,'Recipient','name'), '');
37  const trainingLink = firstNonEmpty(it.json.trainingLink, pick(idx,'驗證','trainingLink'), pick(idx,'Scenario Picker','trainingLink'), linkFromAI(ai), fallbackLink);
38  const scenarioId   = firstNonEmpty(it.json.scenarioId, pick(idx,'驗證','scenarioId'), pick(idx,'Scenario Picker','scenarioId'), '');
39  const scenarioLbl  = firstNonEmpty(it.json.scenario,   pick(idx,'驗證','scenario'),   pick(idx,'Scenario Picker','scenario'),   '');
40
41  const bodyHtml = (ai && typeof ai.bodyHtml == 'string' && ai.bodyHtml.trim())
42      ? ai.bodyHtml
43      : (ai && ai.bodyText ? '<p>' + String(ai.bodyText).replace(/\n/g,'<br>') + '</p>' : '');
44
45  const html =
46    '<p>親愛的同仁' + (name || '') + '：</p>' +
47    bodyHtml + '\n' +
48    '<p><a href="' + trainingLink + '">前往資安演練訓練頁面</a></p>\n' +
49    '<hr>\n' +
50    '<small>此為公司資安演練郵件；所有連結僅導向內部訓練網站。</small>';
51
52  const text    = (ai && ai.bodyText ? ai.bodyText : bodyHtml.replace(/<[^>]+>/g,'')).trim();
53  const subject = firstNonEmpty(ai && ai.subject ? ai.subject.trim() : '', '資安意識演練（' + (scenarioLbl || scenarioId || '') + '）');
54
55  return {
56    json: {
57      subject,
58      text,
59      html: html.trim(),
60      trainingLink,
61      _compose_fallbacks: {
62        usedDefaultTo:  !firstNonEmpty(it.json.email, it.json.to, pick(idx,'驗證','email'), pick(idx,'Scenario Picker','email'), pick(idx,'Recipient','email')),
63        usedDefaultLink:!firstNonEmpty(it.json.trainingLink, pick(idx,'驗證','trainingLink'), pick(idx,'Scenario Picker','trainingLink'), linkFromAI(ai))
64      }
65    }
66  };
67 }).filter(function (row) { return !!row; });
```

釣魚郵件自動化系統

結論

本專案成功將資安演練郵件打造為一條可驗證、追蹤、擴充的自動化流程：不僅降低人工作業成本與錯寄風險，也將公司抬頭等必要訊息一致化，以及強化資安教育的持續性，長期滲透於員工日常，未來可以加上指標化發展，蒐集開信率、點擊率等資料，回傳至資料庫，建立可視化看板，讓隱藏資訊更為清楚，更加了解員工對於釣魚信件的狀況。

後續發展

- **串接資料庫與視覺化平台**：匯入中央資料庫，提供管理階層即時監控員工資安意識的狀況。
- **分級管理上鉤者行為**：細分為「開信但未點擊」、「點擊連結但未輸入資料」、「完成表單輸入」等不同程度。此舉能夠更精準判斷員工的資安風險等級。
- **中鼎大學資安動態課程分發機制**：依照不同的上鉤嚴重程度，自動分派對應的資安訓練內容。
- **長期資安文化建構**：透過週期性寄送、分級教育與追蹤，逐步建立全員的資安防禦思維。

釣魚郵件自動化系統

Notice

CTCI_Notice@ctci.com
收件者 Alan Chang/張鈞傑/CTCI-GRICII
(週二) 下午 4:23

親愛的同仁：

Alice 您好，近期於跨部門協作時，我們注意到財務部共享檔案夾權限設定出現異常，部分同仁可能無法正常存取相關資料。為確保各部門協作順暢，請您確認是否有收到異常存取提醒，並點選下方連結查看詳細說明：
https://www.google.com?uid=E0001&sid=cross_dept

若有任何疑問，歡迎與資訊部門聯繫協助。此為公司資安演練郵件，點擊後將前往訓練頁面。

前往演練訓練頁面

此為公司資安演練郵件；所有連結僅導向內部訓練網站。

CTCI_Notice@ctci.com
收件者 Alan Chang/張鈞傑/CTCI-GRICII
下午 2:31

親愛的同仁：

Alice 您好，

為配合本公司通行證樣式更新作業，請您協助完成以下事項：
- 瀏覽並確認通行證樣式調整內容。
- 若有相關疑問，可回報給行政支援單位。
- 點擊下方連結以檢視更新資訊：https://www.google.com?uid=E0001&sid=admin_support

感謝您的配合。

此為公司資安演練郵件，點擊後將前往訓練頁面

前往演練訓練頁面

此為公司資安演練郵件；所有連結僅導向內部訓練網站。

Notice

CTCI_Notice@ctci.com
收件者 Alan Chang/張鈞傑/CTCI-GRICII
下午 4:50

親愛的同仁：

親愛的 Alice，您好：

針對近期部門會議餐點費用分攤，請您留意下列異動事項：

- 費用分攤比例已依新政策調整，適用於 8 月起所有會議
- 查閱異動明細與分攤明細，請點選以下連結
- 如有疑問，敬請與財務部門聯繫

詳情請參閱：https://www.google.com?uid=E0001&sid=finance_notice

Notice

CTCI_Notice@ctci.com
收件者 Alan Chang/張鈞傑/CTCI-GRICII
8/15 (週五)

Hi ：

您好 Sakura，

近期於本公司檔案伺服器進行例行維護時，部分 HR 專用資料夾出現無法正常存取的情形，請您留意下列事項：

- 若遇檔案開啟或儲存異常，請先重新整理資料夾。
- 重要文件請暫時保留本地，待維護完成再上傳。
- 如需瞭解維護進度與處理建議，請參考說明頁面：https://www.google.com?uid=E0003&sid=sys_maintenance

笑死此為公司資安演練郵件，點擊後將前往訓練頁面

Notice

CTCI_Notice@ctci.com
收件者 Alan Chang/張鈞傑/CTCI-GRICII
8/15 (週五)

Hi ：

Winter 您好，

為協助本公司優化建造營運部專案管理流程，誠摯邀請您參與本次專案回顧意見收集。請您參考下列重點：
- 此問卷僅供內部流程改進參考，無須填寫個人敏感資訊。
- 回饋內容將作為後續專案規劃的重要依據。
- 點擊下方連結即可進入問卷頁面：

https://www.google.com?uid=E0007&sid=internal_survey

笑死此為公司資安演練郵件，點擊後將前往訓練頁面。

前往演練訓練頁面

Information

CTCI_Notice@ctci.com
收件者 Alan Chang/張鈞傑/CTCI-GRICII
8/15 (週五)

Hi ：

Winter 您好：

目前建造營運部負責的內部備份系統空間即將用盡，為確保日後資料不受影響，請依下列步驟檢視相關資訊：
1. 點擊下方專屬連結，確認目前備份空間狀態。
2. 依頁面指示評估是否需清理或調整備份內容。
3. 若有疑問可洽詢部門資訊窗口協助。

https://www.google.com?uid=E0007&sid=system_status

此為公司資安演練郵件，點擊後將前往訓練頁面。